TRIVY IMAGE SCANNING

WHAT IS TRIVY

Trivy is a security scanner used to find vulnerabilities in container images, filesystems, dependencies, and other software artifacts.

INSTALLATION OF TRIVY

1. sudo apt-get install wget apt-transport-https gnupg lsb-release
2. wget -qO - https://aquasecurity.github.io/trivy-repo/deb/public.key | \
   gpg --dearmor | sudo tee /usr/share/keyrings/trivy.gpg > /dev/null
3. echo "deb [signed-by=/usr/share/keyrings/trivy.gpg] https://aquasecurity.github.io/trivy-repo/deb \
   $(lsb_release -sc) main" | \
   sudo tee /etc/apt/sources.list.d/trivy.list
4. sudo apt-get update
5. sudo apt-get install trivy
6. trivy –version

WORKING STEPS FOR TRIVY

In your environment, /tmp had a limited tmpfs quota. Trivy's Java DB download was failing because of that temporary-storage limitation.

Therefore, you created a persistent temporary directory on the root disk.

1. sudo mkdir -p /var/lib/trivy/tmp
2. sudo chown -R ubuntu:ubuntu /var/lib/trivy
3. export TMPDIR=/var/lib/trivy/tmp
4. echo $TMPDIR
5. df -h $TMPDIR

TEST TRIVY MANUALLY ON SERVER

1. trivy image --cache-dir /var/lib/trivy backend:latest

Why do we test manually

To confirm that:

- Trivy is installed correctly
- Docker image exists
- Trivy can access the image
- Trivy databases can be downloaded
- Trivy can complete the image scan

JENKINS PIPELINE — TRIVY IMAGE SCANNING

```
stage('Trivy Image Scanning') {
   steps {
      sh '''
         trivy image \
         --cache-dir /var/lib/trivy \
         --scanners vuln \
         --severity HIGH,CRITICAL \
         --exit-code 0 \
         backend:${BUILD_NUMBER}
      '''
   }
}
```

OPTIONAL — --skip-java-db-update

After the Java DB has been successfully downloaded once, you can add:

So the pipeline becomes:

```
stage('Trivy Image Scanning') {
   steps {
      sh '''
         trivy image \
         --cache-dir /var/lib/trivy \
         --scanners vuln \
         --severity HIGH,CRITICAL \
         --skip-java-db-update \
         --exit-code 0 \
         backend:${BUILD_NUMBER}
      '''
   }
}
```

MEANING

1. Don't try to download/update the Java vulnerability database during this scan.
2. The Java DB must already have been downloaded successfully. It should not be used as a way to bypass the initial Java DB download.

TRIVY FILESYSTEM SCANNING

Trivy Filesystem scans the Jenkins workspace for vulnerable dependencies and exposed secrets before the Docker image is built.

PIPELINE STAGE

```
stage('Trivy Filesystem Scan'){
   steps{
      sh '''
         trivy fs \
         --scanners vuln,secret \
         --severity HIGH,CRITICAL \
         --exit-code 0 \
         .
      '''
   }
}
```

What does it scan:

Jenkins Workspace

1. source code
2. backend (pom.xml)
3. frontend (package.json)
4. Dockerfile
